Relatorio de Arquitetura
No Soberano iSACI

Malha soberana de tramitacao e anonimizacao de documentos juridicos

Projeto PIDE / FAPESPA

Versao: 2.0 - 05 de novembro de 2026

Sucessor do relatorio v1 (16/10/2026, era pre-mTLS/E2E)

Commits: 75d5a64..32b5e7b (malha real + rodada B/C)

Suite: 284 verdes, 5 skipped, 4 xfailed | Malha de 2 nos: provada com pcap

1. Sumario executivo

O iSACI e um no de borda soberano por instituicao para tramitacao e anonimizacao de documentos juridicos. Cada orgao opera a mesma imagem do servico; os papeis (origem/destino) mudam, a stack nao. O binario do documento nunca entra em banco, envelope, broker ou resposta de API - so metadados + SHA-256 circulam entre os nos (invariante T9).

A arquitetura esta provada em execucao, nao so no papel: malha real de dois nos (tjpa x mpfpa) com TLS em todos os links internos, Vault real servindo a chave E2E do no A, round-trip A<->B atraves das bordas mTLS e captura de NIC mostrando zero payload legivel no fio. A esteira de anonimizacao e assincrona e fail-closed: outbox transacional, fila quorum + DLQ, worker com gates deterministicos e trilha de auditoria append-only encadeada por hash.

Distincao honesta: a infraestrutura de custodia esta medida e verde; o nucleo cientifico (motor de anonimizacao) foi medido como cascata POC fora da porta MotorIA - a integracao do pipeline medido na porta e o proximo passo arquitetural.

2. Os tres subsistemas

Subsistema	Onde	Natureza
Malha soberana de tramitacao	app/ (api, worker, relay) + deploy/	Producao-grade: transporte A<->B com custodia criptografica, auditoria e isolamento de rede
Porta MotorIA	anonimizar(bytes)->bytes + app/motor_*.py	Contrato estavel, implementacao permutavel; o motor medido (cascata v2) vive fora da porta, em scripts/
Harness cientifico	corpus/, scripts/eval_*, metricas_prereg, spikes/	Medicao pre-registrada com gabaritos, manifestos e gates - ortogonal ao runtime

3. Topologia e tecnologias por camada

deploy/compose.yaml e o contrato normativo de isolamento (rede interna sem egress, nginx unico na borda, hardening de containers - verificavel estaticamente por test_isolamento.py). deploy/malha/compose.malha.yaml e a prova executavel: dois nos reais com TLS em todos os links internos.

Camada	Tecnologia	Papel
Borda	nginx (TLS 1.3 + mTLS, limit_req, HSTS)	Unico ponto exposto; identidade = CN do cert -> X-Cliente-Orgao; Authorization zerado
Blindagem	MiddlewareE2E ? AEAD ChaCha20-Poly1305 (quadro v2: ts no AAD)	Payload cifrado ponta a ponta: request decifrado antes do roteador, response cifrada; x-e2e-ct allowlist
API	FastAPI + Pydantic v2	Validacao de contrato, erros opacos sanitizados, E2E_OBRIGATORIO=1
Dominio	NoTramitacao (app/service.py)	Maquina de estados, autorizacao centralizada (participacao -> papel -> no), idempotencia
Persistencia	PostgreSQL 16 (asyncpg, alembic)	tramitacoes, trilha hash-chain append-only (trigger), outbox, replay_nonces, idempotencia
Objetos	MinIO/S3	Buckets <org>-docs e <org>-docs-anonimizados; objetos = quadros AEAD (ArmazenamentoCifrado)
Esteira	relay + RabbitMQ (quorum + DLQ) + worker	Outbox transacional -> claim por lease -> publish -> worker -> motor -> gates -> bucket anonimizado
Motor	MotorIA (porta)	stub | demo | ollama | langchain (IA_ENGINE); fail-closed se ausente
Chaves	Cofre: env | Vault KV v2 (AppRole, token 60s)	E2E_CHAVE {atual, anteriores} com rotacao; CofrePseudonimos (ent_id -> rotulo, sem consumidor)
Custodia	Ed25519 (app/assinatura.py)	Envelope e ack assinados; verificacao fail-closed com ORG_SIGN_*/ORGAO_PUBKEYS_*

4. Jornada do documento A -> B

Criar (metadados + hash declarado) -> upload multipart (stream com SHA-256 conferido + magic bytes, <=20 MiB) -> MinIO -> trilha + outbox numa unica transacao. Enviar emite envelope Ed25519 - o binario nao viaja nele. O destino verifica a assinatura, baixa os bytes por download autenticado, arquiva no proprio bucket e so confirma apos recomputar o SHA-256 do proprio storage. O ack volta assinado; a origem aplica e encerra.

Passo	Acao	Garantia exercida
1-2	A: criar + upload	hash declarado = medido; magic bytes; estado CRIADA
3	A -> B: envelope	Ed25519 + destino enderecado; so metadados + hash
4	B: receber	assinatura valida antes de tocar o banco; eco idempotente em duplicata
5	B: baixar bytes	download autenticado; mesmo gate de upload
6	B: confirmar	SHA-256 recomputado do storage de B; ack assinado
7	A: aplicar ack	assinatura do destino exigida; CONFIRMADA/RECUSADA

5. Esteira de anonimizacao (assincrona)

A garantia mora na outbox, nao no broker: o evento DocumentoProntoParaAnonimizacao e gravado na mesma transacao do upload (payload so com ids). O relay (task na API) faz claim por UPDATE condicional com lease - relays paralelos serializam na linha - e marca PROCESSADO so apos publisher-confirm; falha gera tentativas++ com backoff e ESGOTADO + falha_outbox na trilha. O worker (prefetch=1) executa download -> motor -> gates -> upload no bucket anonimizado -> ACK; delivery-limit=3 leva a DLQ, drenada com falha_anonimizacao na trilha.

Gates deterministicos (nao reprocessaveis)

- saida_legivel == False -> falha_anonimizacao:{id}:saida_ilegivel
- residual PII > 0 -> falha_anonimizacao:{id}:residual_pii (nada e gravado no bucket anonimizado)
- sucesso -> objeto em <org>-docs-anonimizados + doc_anonimizado:{id}

Logs e metricas so contam PII por tipo - nunca valores. Efeito sob at-least-once deduplicado por encadear_uma_vez sob a mesma trava consultiva da extensao da trilha.

6. Trilha de auditoria (hash-chain append-only)

- Matematica: topo_n = sha256(topo_{n-1} || evento); cadeia global por no (intercala casos) - divergencia num elo invalida a evidencia de todos
- Concorrencia: pg_advisory_xact_lock serializa a extensao + UNIQUE(hash_anterior) como backstop - bifurcacao vira 409, nunca silenciosa
- Imutabilidade: trigger barra UPDATE/DELETE (migracao 0007)
- Verificacao autonoma: GET /v1/tramitacoes/{id}/verificar rejoga elo a elo - nao confia no topo denormalizado
- Refutabilidade residual (honesta): quem escreve no PG pode reescrever+reencadear - detecta adulteracao de terceiros, nao do DBA malicioso; assinatura por linha e ancora externa sao dividas abertas

7. Seguranca em camadas (cada uma falha sem derrubar a outra)

Camada	Mecanismo	Politica por canal
Identidade	mTLS no nginx -> X-Cliente-Orgao + BORDA_SEGREDO opcional	JWT removido (reprovado - exfiltravel). 3 portoes 401 opacos: header, formato OrgaoID, segredo compare_digest
Payload	Quadro v2 AEAD: 0xE2|0x02|nonce|len|ts|ct	HTTP: frescura 300s + replay_nonces (claim por PK, multi-replica); AMQP: so frescura (redelivery legitima); S3/DLQ: sem janela (repouso/forense)
Custodia	Ed25519 envelope/ack	Fail-closed quando configurado; confirmar recomputa hash; upload so em CRIADA/RECEBIDA

Camada	Mecanismo	Politica por canal
Evidencia	Trilha hash-chain + outbox transacional	Append-only por trigger; efeito deduplicado por encadear_uma_vez
Chaves	Vault KV v2 + AppRole	No A provou E2E_FONTE=vault real; token curto 60s; rotacao sela-com-atual/abre-com-todas
Rede	interna internal:true	Sem egress; so nginx na borda; TLS em todos os links internos (amqps, pg-ssl, minio/vault https)

8. Validacao executada (05/11/2026) - medido

Prova	Metodo	Resultado
Suite smoke/e2e	pytest -q	285 verdes, 5 skipped, 4 xfailed
Migracoes 0006/0007	alembic upgrade no Postgres 16 real da malha	aplicadas limpas (era divida aberta)
Round-trip A<->B	prova_malha.py no container peer rede borda (mTLS+E2E real)	criar 201, upload 201, envio 200, em_transito, recebimento B 200 com hash_cadeia
Prova de NIC	tcpdump no netns dos apis + prova_pcap.py	interna-a: 37 registros TLS + 17 quadros E2E; interna-b: 14 + 7; ZERO bytes legiveis (sentinela, caso_cnj, JSON, credenciais)
Trilha verificavel	GET .../verificar no no A	integro=True; 12 linhas rejogadas elo a elo; topo recomputado confere
Cofre real	worker-a via AppRole no Vault	GET 200 no segredo isaci/e2e (E2E_FONTE=vault provado)
Download E2E	GET /download na malha travava: receive_claro esgotado devolvia http.request infinito e listen_for_disconnect girava (loop 100% CPU)	corrigido: delega ao receive real apos EOF; download 200 na malha + regressao em teste
Esteira no no destino	orgao_no = dono do storage (era a origem do caso ? worker de B buscaria bucket errado); cada no anonimiza a propria copia	corrigido e provado na malha: trilha de B recebida->doc_arquivado->doc_anonimizado; download-anonimizado 200 (prova_esteira_b)

Contrato (verificado estaticamente): topologia do compose, nginx.conf, mounts :ro, E2E_OBRIGATORIO=1. Nao avaliado nesta rodada: latencia/overhead da cifragem, carga, CRL/OCSP, backup/retencao LGPD.

9. Estado medido do motor (POC - fora da porta)

O deploy usa MotorOllama single-pass (IA_ENGINE). O que foi medido e a cascata v2 no harness (det regex + spans LLM + poda de fronteira + validador CPF mod-11 + res:NOME) - ainda nao plugada na porta MotorIA. ADR-0011 (zero IA generativa) segue como regra aprovada; o LLM como extrator e desvio documentado de POC. Retorno a ADR exige NER discriminativo medido no mesmo gate.

Medicao	Resultado
Cascata v0 (teste, 80)	NER exact F1 0.755 < gate 0.85 (FAIL); recall 356/360; reident doc 4/80
Cascata + poda (04/11)	exact F1 0.919 (PASS); overlap 0.972; recall 357/360; reident 3/360
Cascata v2 (04/11)	exact F1 0.953; overlap 1.000; recall 360/360; reident 0/360
Coreferencia corpus_v0	pairwise F1 1.000; consistencia 90/90; anti-merge 0/270
Nao avaliado	utility TAB >= 0.85; latencia; corpus real (depende de exclusao juridica)

10. Limitacoes honestas e divida ativa

- Chave simetrica por par de nos: vazamento decifra E forja nos dois sentidos; camada E2E sem PFS (TLS do hop mitiga)
- Hop nginx->api e HTTP em claro na interna carregando quadros E2E (headers legiveis, payload nao - e o desenho)
- org e parametro confiavel dentro do servico - endpoint interno futuro e bypass potencial de autorizacao

- Trilha detecta adulteracao, nao impede DBA malicioso reescrever+reencadear (sem assinatura por linha/ancora externa ainda)
- Ack B->A tem prova de autoria (Ed25519) mas nao mecanismo de re-entrega - A pode ficar EM_TRANSITO apos B terminal
- Produto especificado != implementado: sem /v1/anonymize, sem cofre HMAC/DEK por caso, modo=pseudonimizacao e metadado inerte
- replay_nonces.expira_ms sem indice (varredura oportunista); credencial MinIO unica para todos os buckets do no
- CRL/OCSP, alerta de ESGOTADO, retencao/eliminacao LGPD, backup, sandbox de parser hostil, metadados DOCX/imagem, caso_cnj em claro (decisao DPO)

11. Proximos passos (ordem de dependencia)

#	Item	Estado
1	NER discriminativo na porta MotorIA (sair do desvio ADR-0011)	aberto - cascata v2 medida fora da porta; portar ou treinar
2	Decisao juridica de reidentificacao + integracao ent_id/mapa (CofrePseudonimos)	aberto - mecanismo pronto, sem consumidor
3	Corpus real (Etapa 3)	bloqueado - depende das exclusoes juridicas
4	Re-entrega do ack B->A + sweeper de EM_TRANSITO	aberto
5	Decidir papel de B na esteira de anonimizacao	aberto
6	Gates utility TAB e latencia	nao avaliados
7	Operacao: CRL/OCSP, alerta ESGOTADO, backup, retencao LGPD, assinatura por linha da trilha	divida ativa

12. Inventario documental

- AGENTS.md - invariantes, estrutura, estado medido, proximos passos (fonte primaria)
- docs/divida-tecnica.md - rodada B/C detalhada
- docs/adr/0000..0013 - decisoes (0006 emendado: mTLS; 0011: zero IA generativa)
- docs/relatorio_seguranca_e2e.pdf - provas da camada E2E
- docs/metricas.md - gates pre-registrados; relatorio_avaliacao.pdf - medicao do motor
- docs/relatorio-arquitetura.pdf - v1 (16/10, historico)
- fluxogramas: docs/img/fluxograma_simples.png (apresentacao), fluxograma_arquitetura.png (detalhado), docs/fluxograma-arquitetura.html (interativo)
- provas: scripts/prova_malha.py, prova_pcap.py, test_mtls_real.py, test_seguranca_b.py

Apendice A - jornada do documento



fig. A - jornada em 7 passos (docs/img/fluxograma_simples.png)

Apendice B - stack interna detalhada

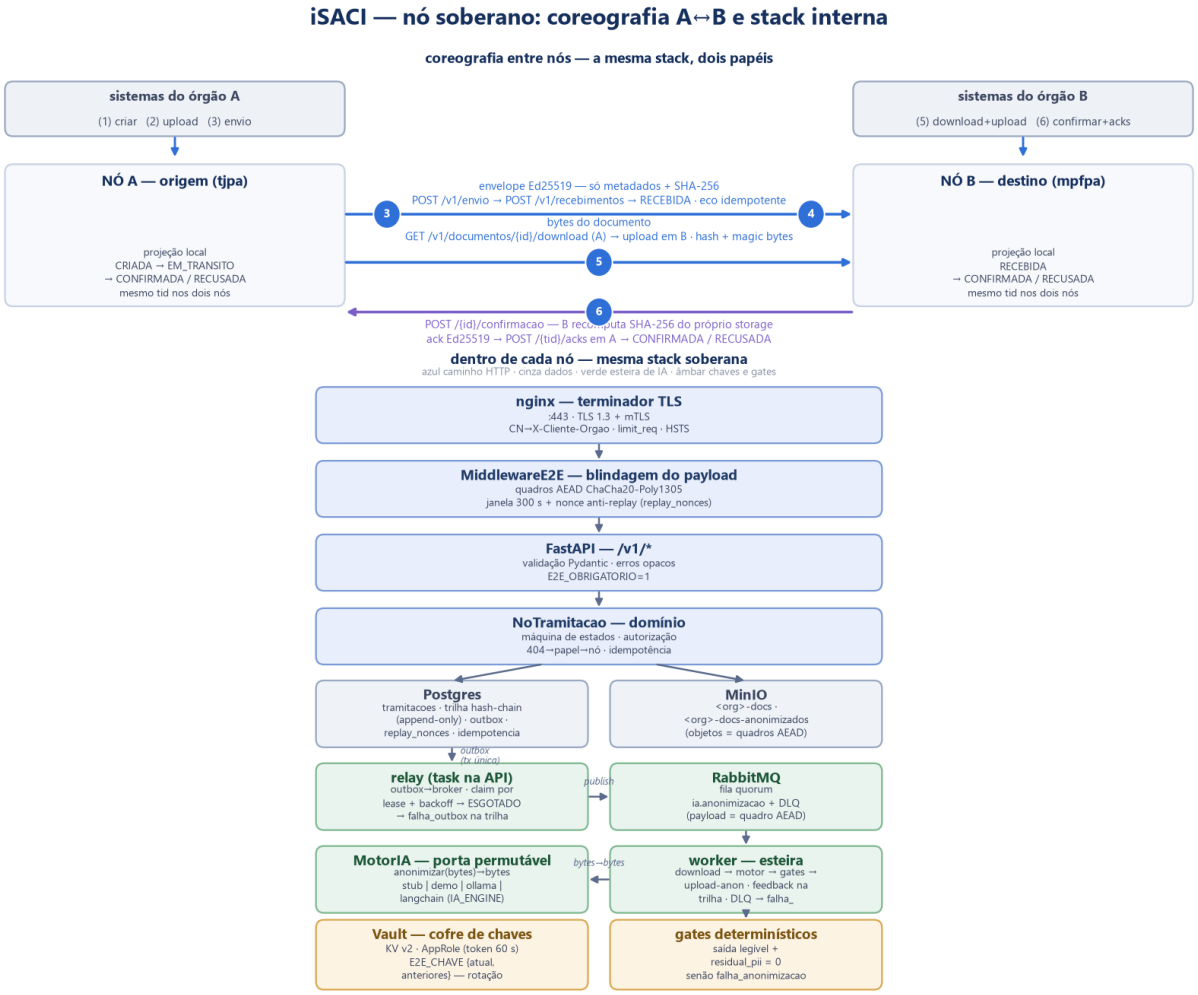


fig. B - coreografia A<->B + stack interna unica (docs/img/fluxograma_arquitetura.png)